Lab 45 — Governance: Policies, Standards, Procedures

> **SY0-701 Objective 5.1** — Summarize elements of effective security governance
>
> **Domain 5** — Security Program Management and Oversight (20%) · **Time:** ~20 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: Turn the governance document hierarchy into real, enforced artefacts on a Linux host.

You'll build: A governance pack — an acceptable use policy, a password standard, an onboarding procedure and a RACI data-roles chart — with the standard actually enforced by pwquality, a login banner and a least-privilege sudoers rule.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; `libpam-pwquality` installed in step 1.

Background

- Governance is a hierarchy: a **policy** states management intent (what/why), a **standard** is a mandatory specific requirement that implements it, a **procedure** is the step-by-step how, and a **guideline** is optional advice.
- A **directive** control instructs people what to do — an acceptable use policy and a login banner are directive, not technical.
- A **standard** is only real when it is enforced technically; here the password standard is enforced by `pam_pwquality`.
- Data roles make people accountable: an **owner** sets classification, a **controller** decides why/how personal data is processed, a **processor** acts on the controller's instructions, and a **custodian/steward** operates the data day to day.
- Governance must be **monitored and revised**, so every document carries an owner and a review date.

Steps

1. Install the tools

The password standard is enforced by the PAM pwquality module.

```
apt-get update -qq && apt-get install -y libpam-pwquality
mkdir -p ~/governance && cd ~/governance
```

2. Write the acceptable use policy

A policy is broad and mandatory. It says what is and is not allowed, and why.

```
cd ~/governance
cat > aup.md <<'EOF'
# Acceptable Use Policy (POLICY)
```

```
Owner: CISO   Review: annual
1. Company systems are for authorised business use only.
2. Users must not share credentials or disable security controls.
3. All activity on company systems may be monitored and logged.
4. Suspected security incidents must be reported within 1 hour.
EOF
cat aup.md
```

3. Write the password standard

A standard turns the policy's intent into a specific, measurable requirement.

```
cd ~/governance
cat > password-standard.md <<'EOF'
# Password Standard (STANDARD — implements the AUP)
Owner: Security Engineering   Review: annual
- Minimum length: 12 characters
- Must include upper, lower and digit character classes
- Reject dictionary words and the username
- Enforced technically via pam_pwquality
EOF
cat password-standard.md
```

4. Enforce the standard with pwquality

The standard is only real once the host rejects non-compliant passwords.

```
sed -i 's/^#\?\s*minlen.*/minlen = 12/' /etc/security/pwquality.conf
sed -i 's/^#\?\s*minclass.*/minclass = 3/' /etc/security/pwquality.conf
grep -E '^(minlen|minclass)' /etc/security/pwquality.conf
# Prove it rejects a weak password (non-interactive check):
echo 'short' | pwscore || echo "REJECTED: weak password blocked by the standard"
```

5. Add a directive login banner

A login banner is a directive control — it instructs and warns before access.

```
printf '%s\n' 'AUTHORISED USE ONLY. Activity on this system is monitored and logged.' >
/etc/issue.net
printf '%s\n' 'AUTHORISED USE ONLY. Activity on this system is monitored and logged.' >
/etc/issue
cat /etc/issue.net
```

6. Write the onboarding procedure

A procedure is step-by-step and names the role that performs each action.

```
cd ~/governance
cat > onboarding.md <<'EOF'
# Onboarding Procedure (PROCEDURE)
Role: IT Service Desk   Trigger: HR new-joiner ticket
1. Create the account with least privilege only.
2. Add to role groups the manager approved in writing.
```

```
3. Issue MFA token and record the serial.
4. Capture signed AUP acknowledgement.
5. Record completion in the asset register.
EOF
cat onboarding.md
```

7. Apply a least-privilege sudoers rule

Procedures often set access; least privilege means granting only what the role needs.

```
cat > /etc/sudoers.d/helpdesk <<'EOF'
# Help desk may restart web services only — least privilege
%helpdesk ALL=(root) /usr/bin/systemctl restart nginx, /usr/bin/systemctl status nginx
EOF
chmod 440 /etc/sudoers.d/helpdesk
visudo -cf /etc/sudoers.d/helpdesk
```

8. Build the RACI data-roles chart

Map the SY0-701 data roles to a concrete data set so accountability is explicit.

```
cd ~/governance
cat > raci.csv <<'EOF'
data_set,owner,controller,processor,custodian_steward
Customer PII,Head of Sales,Company (us),Cloud CRM vendor,DBA team
Payroll data,Head of HR,Company (us),Payroll provider,HR systems admin
EOF
column -t -s, raci.csv
```

Test it

```
grep -E '^(minlen|minclass)' /etc/security/pwquality.conf
echo 'password' | pwscore || echo "weak password correctly REJECTED"
cat /etc/issue.net
visudo -cf /etc/sudoers.d/helpdesk && echo "sudoers OK"
column -t -s, ~/governance/raci.csv
```

Expected: pwquality shows `minlen = 12` and `minclass = 3`; the weak password is rejected; the banner prints; the sudoers file parses OK; and `raci.csv` names an owner, controller, processor and custodian/steward for each data set.

Troubleshooting

Symptom	Fix
`pwscore: command not found`	The package is `libpam-pwquality`; re-run step 1.
`pwscore` accepts a weak password	Confirm `/etc/security/pwquality.conf` has `minlen` / `minclass` uncommented (step 4).
`visudo -cf` reports a syntax error	A command path must be absolute; check the paths in `/etc/sudoers.d/helpdesk`.

Challenge

Write a **guideline** file (optional advice) that helps staff choose a strong passphrase, and explain in one line why it is a guideline and not the standard.

Reflection

Objective 5.1 separates policy, standard, procedure and guideline. In this lab, which single artefact was the *standard*, and what made it enforceable rather than merely aspirational?

Exam tips

- Policy = what/why (broad, mandatory); standard = specific requirement; procedure = step-by-step how; guideline = optional advice.
- A login banner and an AUP are **directive** controls, not technical ones.
- Controller decides why/how personal data is processed; processor acts on its instructions. Owner sets classification; custodian/steward operates.
- Centralized governance is consistent and auditable; decentralized is faster and closer to local risk.

References

- NIST SP 800-12 (security program) — https://csrc.nist.gov/pubs/sp/800/12/r1/final
- CIS Controls (governance and account management) — https://www.cisecurity.org/controls
- Linux PAM pwquality — https://man7.org/linux/man-pages/man5/pwquality.conf.5.html

---